

User Authentication with 802.1X

CONTENTS

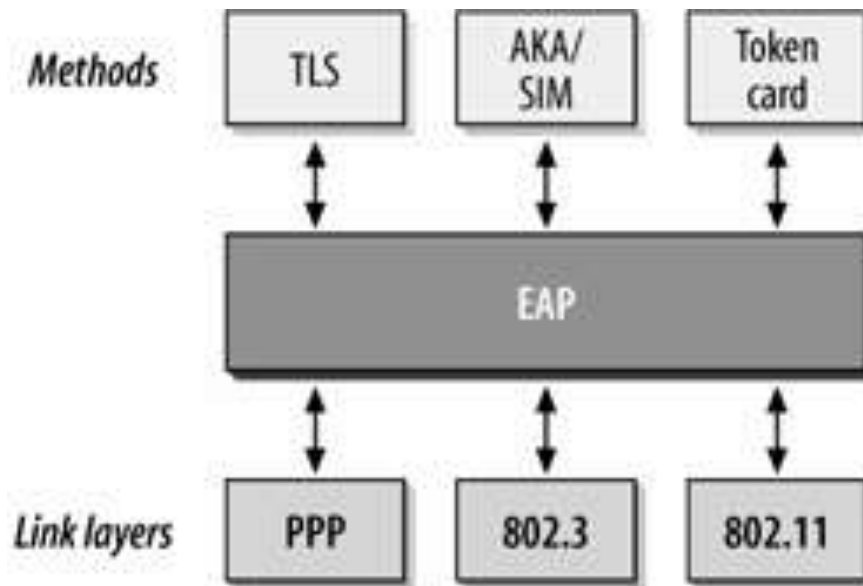
- **The Extensible Authentication Protocol**
- **EAP Methods**
- **802.1X: Network Port Authentication**
- **802.1X on Wireless LANs**

802.1X

- 802.1x is one of the method that provides link layer authentication in wireless networks.
- 802.1X authenticates users rather than machines.
- **Identifying users instead of machines can lead to**
 1. more effective network architecture
 2. Access rights can be integrated with user identity.
- **802.1X is based on EAP** (Extensible Authentication Protocol)
 - **EAP is a framework protocol.**

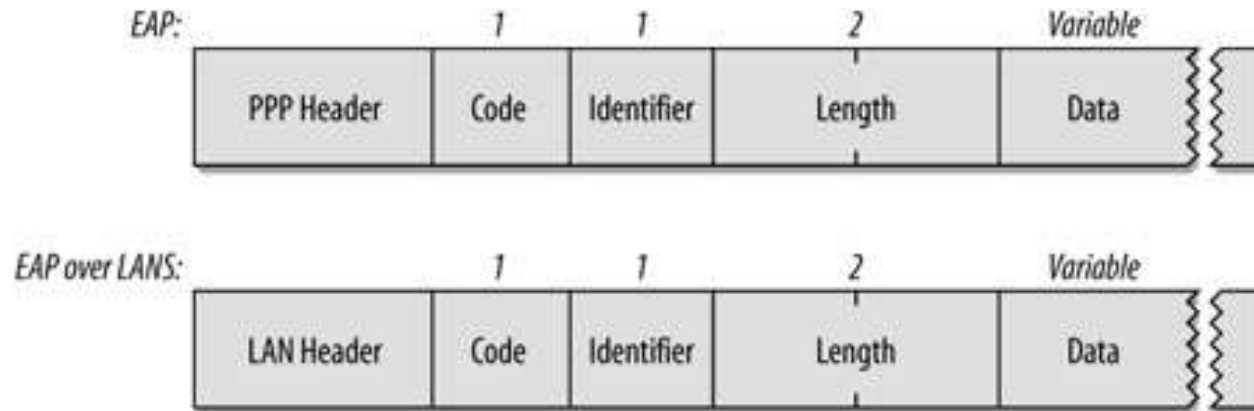
The Extensible Authentication Protocol

- [Figure](#) shows the basic EAP architecture, which is designed to run over any link layer



The Extensible Authentication Protocol

EAP Packet Format



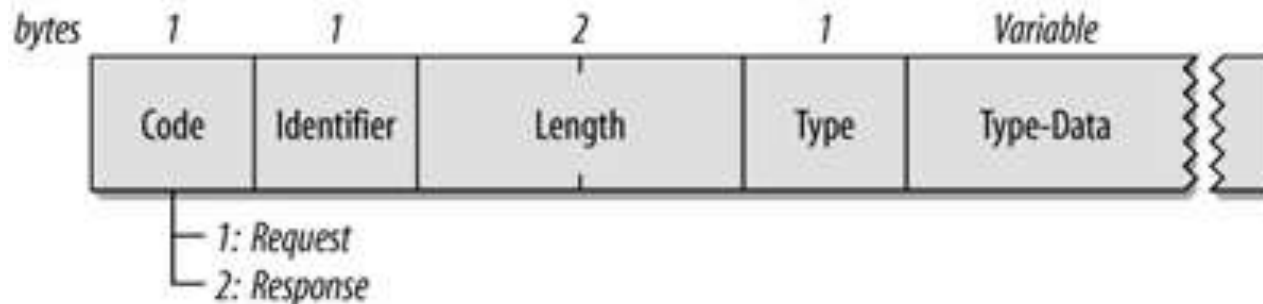
- There is no strict requirement that EAP run on PPP; the packet can be carried in any type of frame.

The Extensible Authentication Protocol

EAP Requests and Responses

- EAP exchanges are composed of requests and responses
- One who sends request – Authenticator
- One who sends the response – Client (User)

EAP Request and EAP Response packets



Each Data field carries one type of data, broken down into a type identifier code and the associated data:

The Extensible Authentication Protocol

EAP Requests and Responses

Type

- one-byte field that indicates the type of request or response.
- Only one type is used in each packet.
- Types greater than or equal to 4 indicate authentication methods.

Type-Data

- The Type-Data field is a variable field that must be interpreted according to the rules for each type.

The Extensible Authentication Protocol

EAP Requests and Responses

Type code 1: Identity

- The authenticator uses the Identity type as the initial request authenticating the client.
- written as **EAP-Request/Identity**, or simply **Request/Identity**
- **Data can be zero byte or some information.**
- If any information is present in the Type-Data field, it is used to prompt the user
- EAP client will respond with a Response/Identity packet.
 - the Type-Data field contains the username

The Extensible Authentication Protocol

EAP Requests and Responses

Type code 2: Notification

- The authenticator can use the Notification type to send a message to the user.
- provide messages to the user from the authentication system, such as a password about to expire, or the reason for an account lockout.
- **Response has data field zero bytes to indicate the acknowledgement.**

The Extensible Authentication Protocol

EAP Requests and Responses

Type code 3: NAK

- This is a response sent by the client to indicate that it doesn't support the requested authentication method by authenticator.
- It also suggests the authentication method to the authenticator.
- The Type-Data field of a NAK message includes a single byte corresponding to the suggested authentication type.

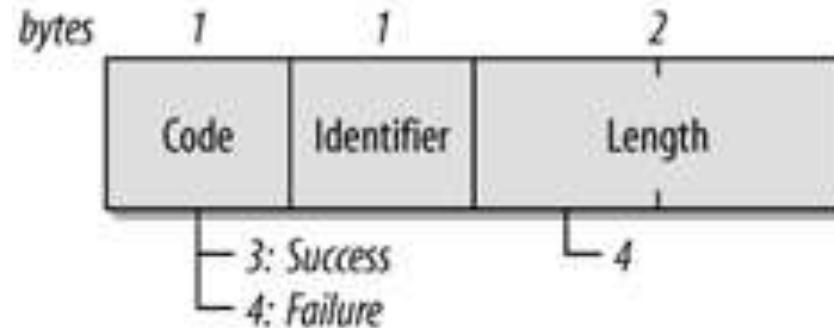
The Extensible Authentication Protocol

EAP Authentication Methods

Type code	Authentication protocol	Description
4	MD5 Challenge	CHAP-like authentication in EAP
6	GTC	Originally intended for use with token cards such as RSA SecurID
13	EAP-TLS	Mutual authentication with digital certificates
21	TTLS	Tunneled TLS; protects weaker authentication methods with TLS encryption
25	PEAP	Protected EAP; protects weaker EAP methods with TLS encryption
18	EAP-SIM	Authentication by mobile phone Subscriber Identity Module (SIM)
29	MS-CHAP-V2	Microsoft encrypted password authentication; compatible with Windows domains

The Extensible Authentication Protocol

EAP Success and Failure

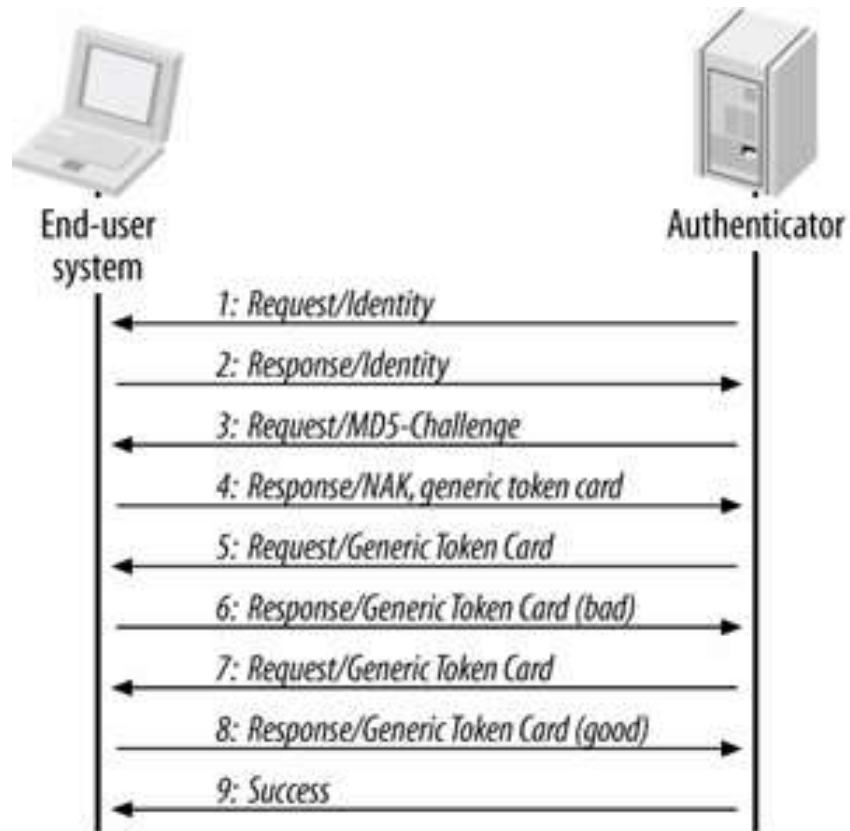


Authenticator determines that the exchange is complete, it can issue an EAP-Success (code 3) or EAP-Failure (code 4) frame to end the EAP exchange

The Extensible Authentication Protocol

A Sample EAP Exchange

EAP method exchange are written Request/Method when they come from the authenticator, and Response/Method when they are sent in response.



EAP Methods

Cryptographic Methods

- 1. LEAP**
- 2. Code 13: EAP-TLS**
- 3. Code 21: EAP-TTLS and Code 25: EAP-PEAP**

Non- cryptographic EAP Methods (Inner Authentication Methods)

- 1. Code 4: MD-5 Challenge**
- 2. Code 6: Generic Token Card**
- 3. Code 29: EAP-MSCHAP-V2**
- 4. Code 18: EAP-SIM and Code 23: EAP-AKA**

Other Inner Authentication Methods

- 1. Password Authentication Protocol (PAP)**
- 2. Challenge Handshake Authentication Protocol (CHAP)**
- 3. MS-CHAP, version 1**

EAP Methods

Cryptographic Methods

- **Cryptographic Methods should meet three major goals:**
 - 1. Strong cryptographic protection of user credentials**
 - 2. Mutual authentication**
 - Network validates client and client validates Network
 - Strong guard against so-called "rogue" access points.
 - 3. Key derivation**
 - Security protocols need to use dynamic keys that are derived from an entropy pool.

EAP Methods

Cryptographic Methods

LEAP (Lightweight EAP)

- Cisco's proprietary authentication protocol based on username/password.
- **LEAP is two MS-CHAP version 1 exchanges.**
 - One authenticates the network to the user, .
 - The second authenticates the user to the network.
- Dynamic keys are derived from the MS-CHAP exchanges.

Advantage:

- Better security benefits compared to manually keyed WEP

EAP Methods

Cryptographic Methods

LEAP (Lightweight EAP)

Drawbacks:

- User credentials are not strongly protected
 - Can be susceptible to eavesdropping.
-
- CISCO no more recommends this.

EAP Methods

Cryptographic Methods

Code 13: EAP-TLS (Transport Layer Security)

- Establishes a **trusted communication channel** over an untrusted network
- **Mutual authentication through certificate exchange**
 - The user is required to submit a digital certificate
 - Authentication server must also supply a certificate
 - **Validations are carried out by verifying the certificate with a listed of trusted certificate authorities.**

EAP Methods

Cryptographic Methods

- **Meets all three goals for wireless networks.**
 - Certificates provide strong authentication
 - Mutual authentication through Certificate
 - Establishes a master secret that can be used to derive keys
- **Drawbacks**
 - Uses digital certificates for both user and server authentication
 - **Major challenge:** Generating and distributing certificates
 - **Major bar :** Need of **public key infrastructure (PKI)**

EAP Methods

Cryptographic Methods

Code 21: EAP-TTLS and Code 25: EAP-PEAP

- **Tunnelled TLS (TTLS) and Protected EAP (PEAP)**
- **Basically extends TLS.**
- **Both work in a similar fashion. Method has two steps:**
 1. Establish a TLS tunnel: Digital certificates on the authentication server are used to validate the network
 2. TLS tunnel is used to encrypt authentication protocol that authenticates the user to the network.
- The first step is **"outer" authentication**, the second is **"inner" authentication**.

EAP Methods

Cryptographic Methods

Code 21: EAP-TTLS and Code 25: EAP-PEAP

Advantages:

- Certificates are required only for the **“outer”** authentication
- **“Inner”** and **“outer”** authentications can use distinct usernames.

Difference:

- TTLS uses the encrypted channel to exchange attribute-value pairs (AVPs)
- PEAP uses the encrypted channel to start a second EAP exchange inside of the tunnel.

EAP Methods

Noncryptographic EAP Methods

- Not suitable for use directly on wireless networks
- Useful as inner authentication methods with PEAP or TTLS

Code 4: MD-5 (Message Digest) Challenge

- User authenticated by password
- Authentication Requests contain a challenge to the end user.
- End user encodes the challenge with a shared secret(passwd)
- All EAP implementations must support the MD-5 Challenge.
- **Not widely supported on wireless networks as there is no key management or dynamic key**

EAP Methods

Noncryptographic EAP Methods

Code 6: Generic Token Card

- Basically a One Time Password (OTP) system.
- The Request contains the Generic Token Card information necessary for authentication.
- In the Response, the Type-Data field is used to carry the information copied from the token card by the user.
- It allows the exchange of cleartext authentication credentials across the network

EAP Methods

Noncryptographic EAP Methods

Code 29: EAP-MSCHAP-V2

- Initially introduced in Windows 2000
- **Designed to address the drawbacks of MS-CHAP by eliminating**
 - the weak encoding of passwords for older clients,
 - providing mutual authentication,
 - improving keying and key generation
- Commonly supported and used as an inner authentication method with PEAP.

EAP Methods

Noncryptographic EAP Methods

Code 18: EAP-SIM(Subscribers Identity Module) and Code 23: EAP-AKA (Authentication and Key Agreement)

- Both methods are used for authentication against mobile telephone databases
- **EAP-SIM** **SIM** database on GSM telephone networks.
- EAP-AKA is based on the authentication system in third-generation mobile telephone networks.

EAP Methods

Other Inner Authentication Methods

Password Authentication Protocol (PAP)

- Originally specified for use with PPP .
- PAP transmits unencrypted username and password across the network . **So with wireless networks, use it as an inner method inside of TTLS**
- PAP can be used with any type of authentication system

EAP Methods

Other Inner Authentication Methods

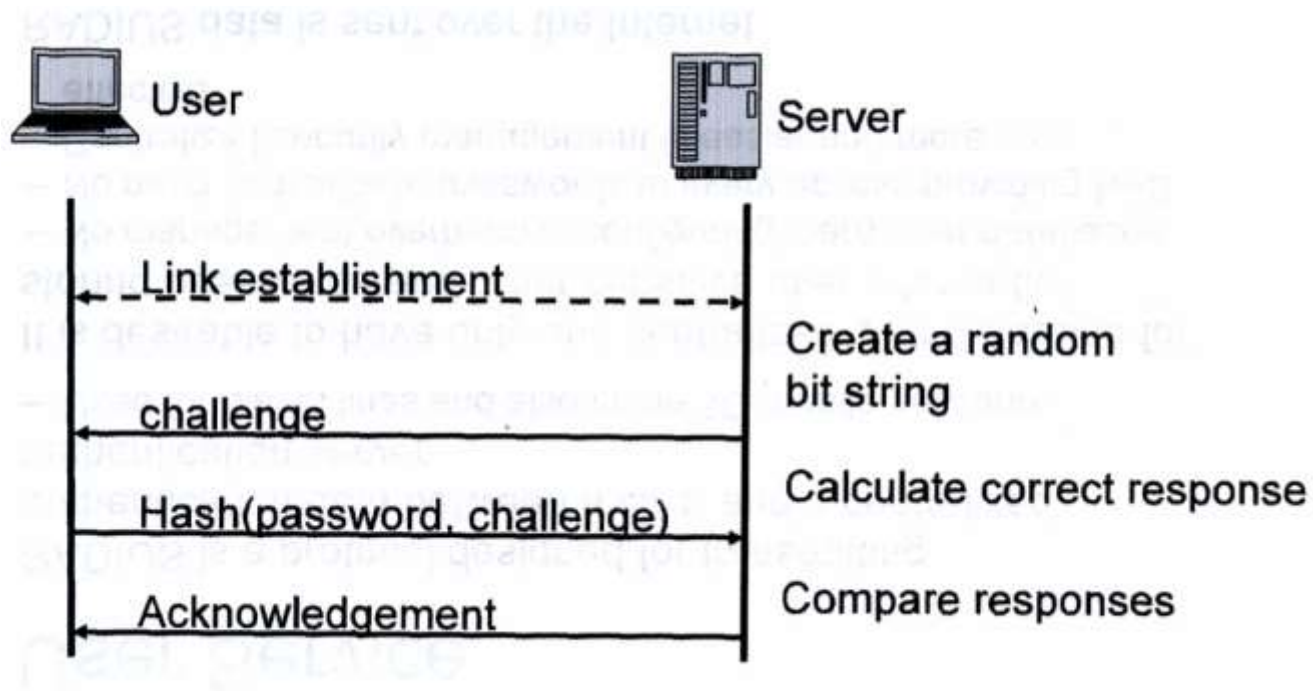
Challenge Handshake Authentication Protocol (CHAP)

- Like PAP, CHAP was designed for use with PPP .
- CHAP is two step,
 1. the authentication server challenges the client,
 2. Client proves that it is in possession of the shared secret by successfully responding to the challenge.
- **Drawback**
 - Requires the password in cleartext at both ends of the link

EAP Methods

Other Inner Authentication Methods

The CHAP 3-way handshake



EAP Methods

Other Inner Authentication Methods

MS-CHAP, version 1

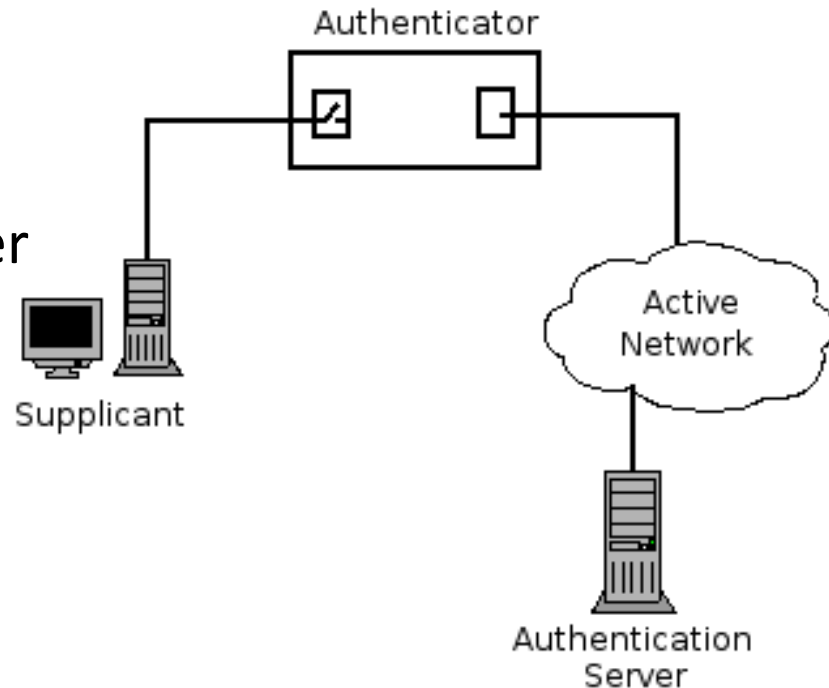
- proprietary to Microsoft and similar to CHAP
- Instead of using the clear text password as the shared secret, MS-CHAP uses the MD4 hash of the user password.
- useful in environments where Microsoft authentication databases are used

802.1X: Network Port Authentication

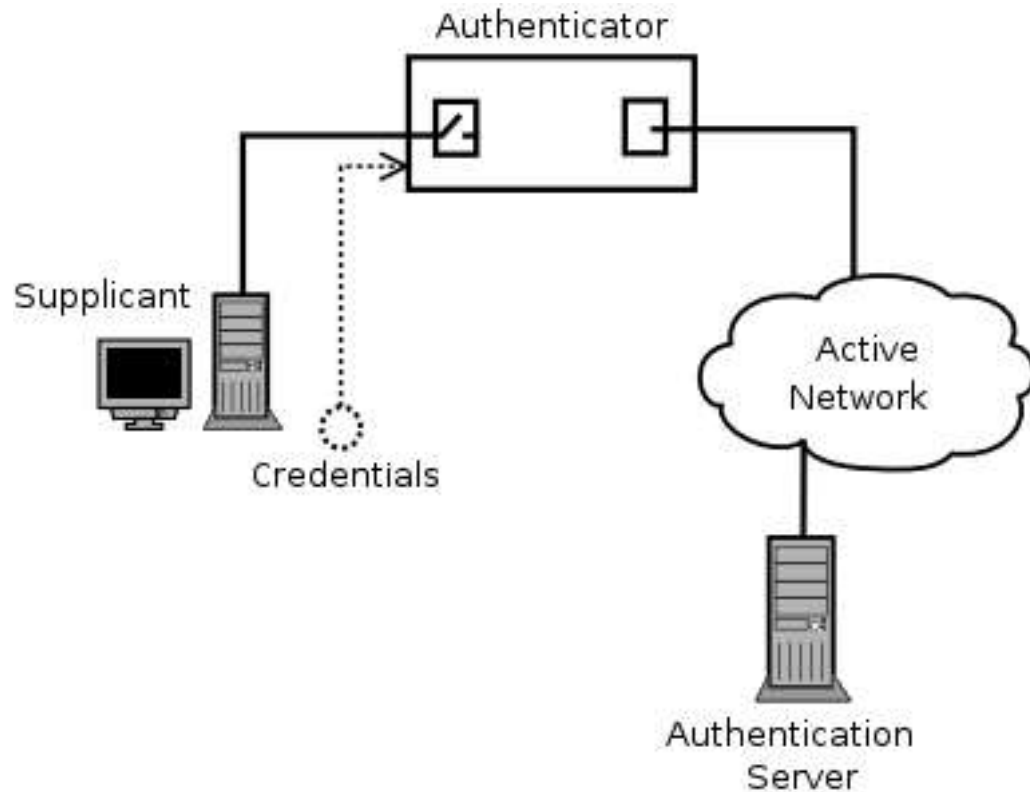
- The Port-Based Authentication Protocol was introduced with an intention to prevent unauthorized users from using the network through a system connected over LAN.

802.1X: Network Port Authentication

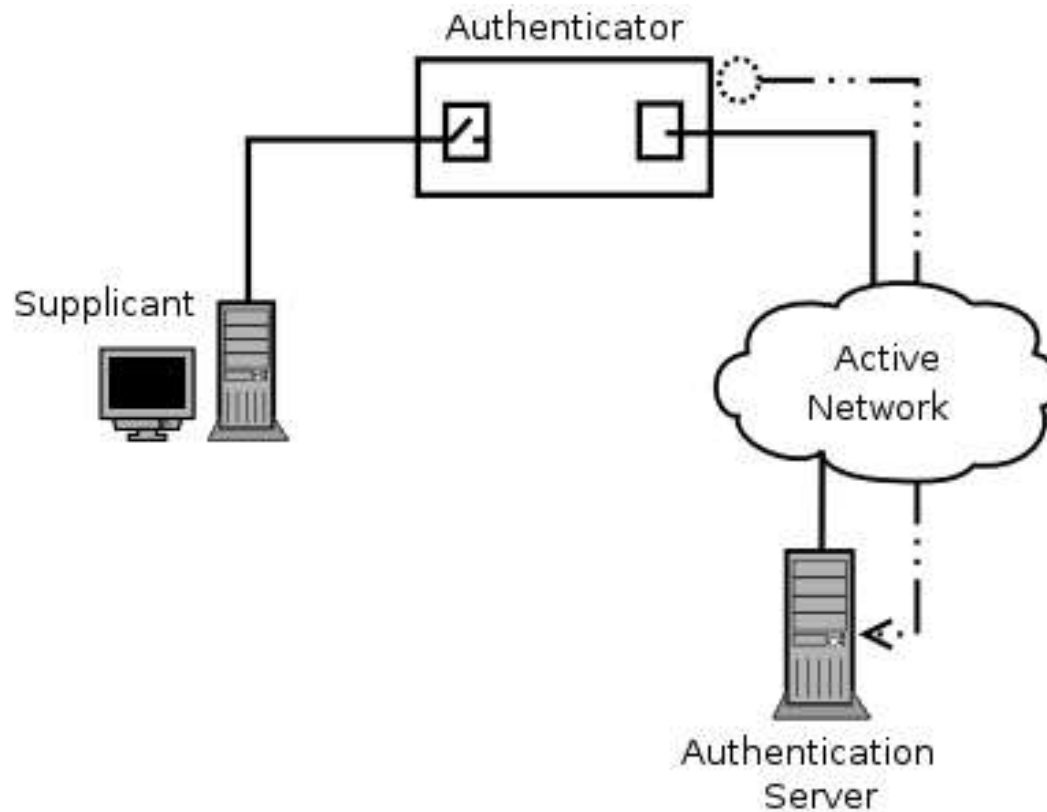
- The Port-Based Authentication Protocol works with three parts.
 - Supplicant
 - Authenticator
 - Authentication Server



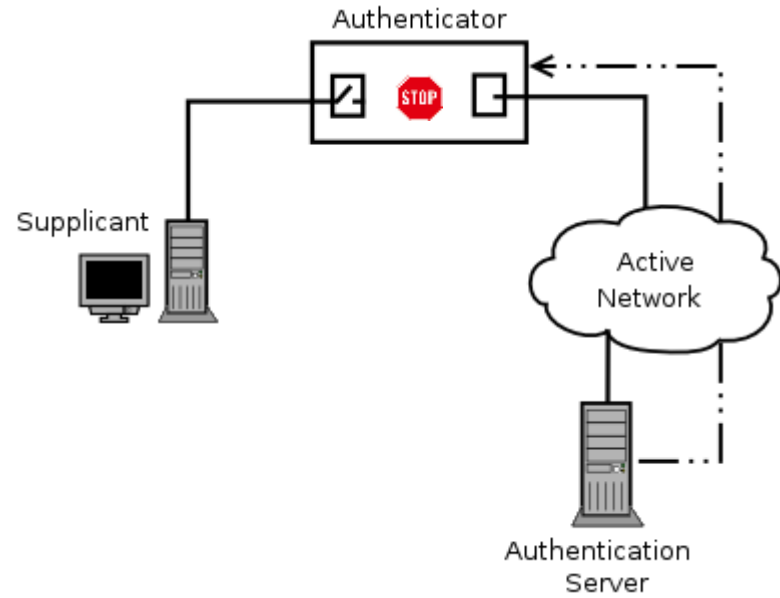
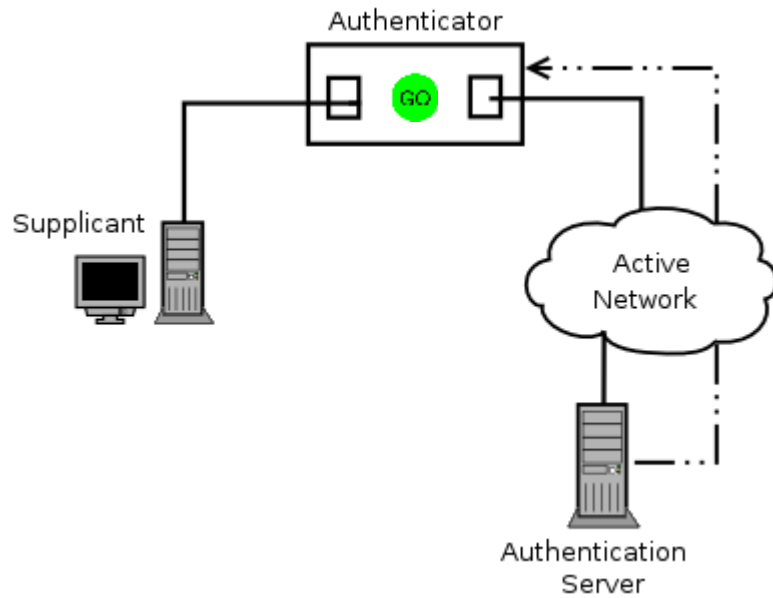
802.1X: Network Port Authentication



802.1X: Network Port Authentication

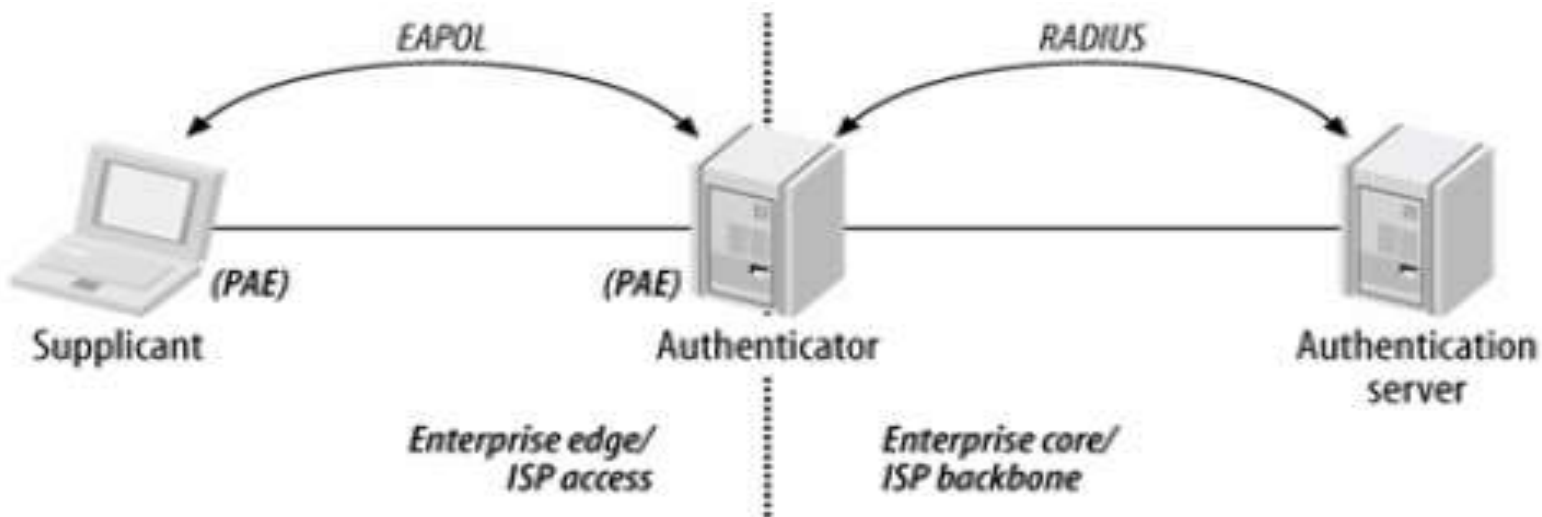


802.1X: Network Port Authentication Process



802.1X: Network Port Authentication

802.1X Architecture and nomenclature



- 3 components to the authentication conversation
 1. Supplicant
 2. authenticator (Access Point – 802.11/Switch - Ethernet)
 3. Authentication server (RADIUS Server)

802.1X: Network Port Authentication

802.1X Architecture

- ⦿ **The supplicant is**

- ⦿ the end user machine that seeks access to network resources.

- ⦿ **Authenticator**

- ⦿ Controls Network access .
 - ⦿ Terminates the link-layer authentication exchange.

802.1X: Network Port Authentication

802.1X Architecture

- ⦿ Authentication Server
 - ⦿ Maintains user credentials
 - ⦿ Decides whether give to access or not

802.1X: Network Port Authentication

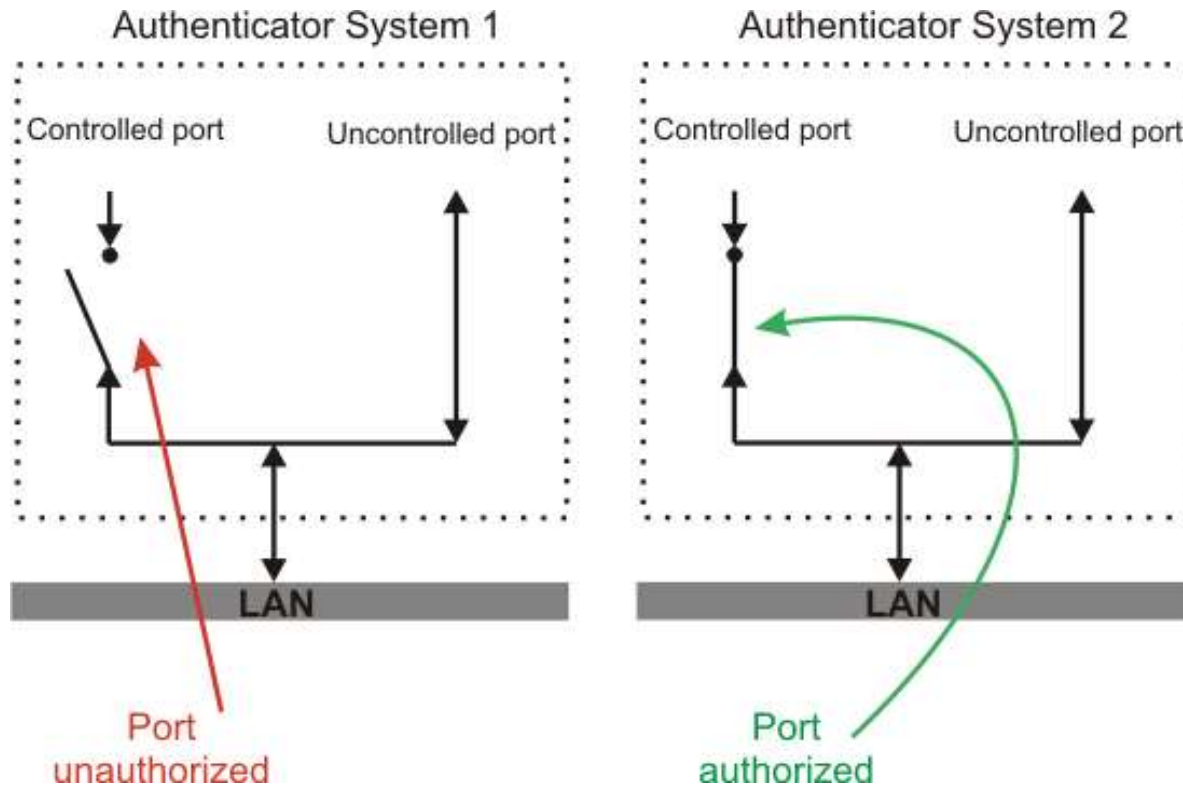
802.1X Architecture

- ⦿ Ports on an 802.1X-capable device are in one of the two states:
 - ⦿ **An authorized state**, in which the port is enabled,
 - ⦿ **or an unauthorized state**, in which it is disabled.
 - ⦿ DHCP and other initialization traffic is permitted by a network manager.

802.1X: Network Port Authentication

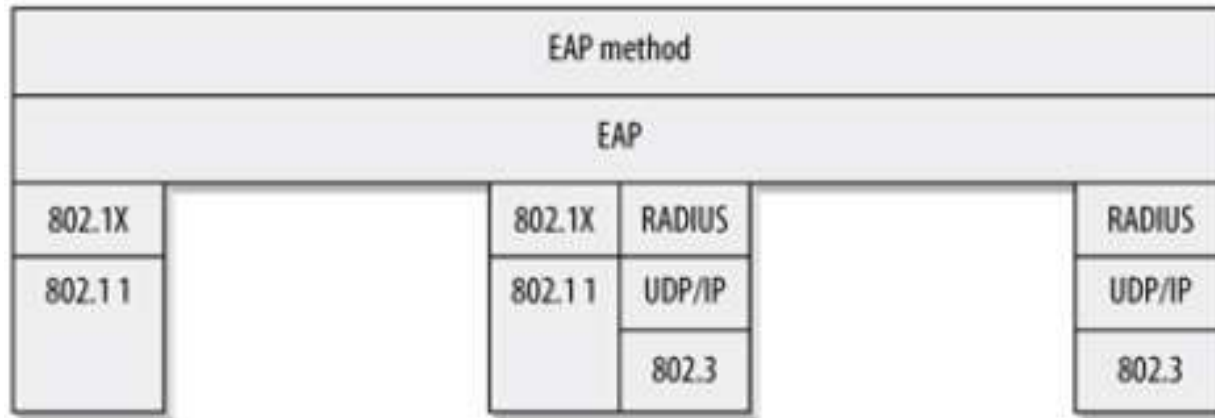
802.1X Architecture

- Ports on an 802.1X-capable device



802.1X: Network Port Authentication

802.1X logical protocol Architecture

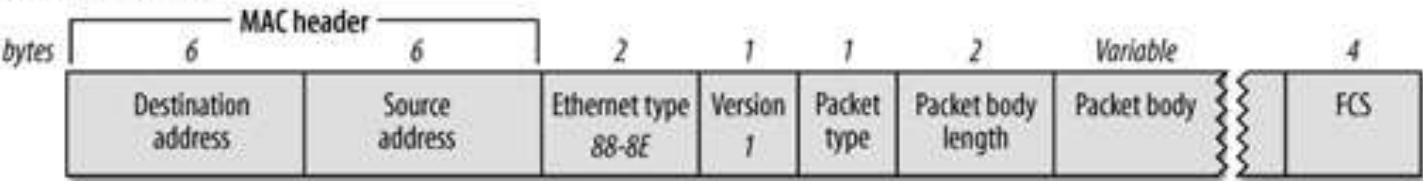


- Procees:
- The authentication exchange is logically carried out between the supplicant and the authentication server
- The authenticator acting only as a bridge.
- From the supplicant to the authenticator (the "front end"), the protocol is EAP over LANs (EAPOL),
- On the "back end," EAP is carried in RADIUS packets. (EAP over RADIUS)

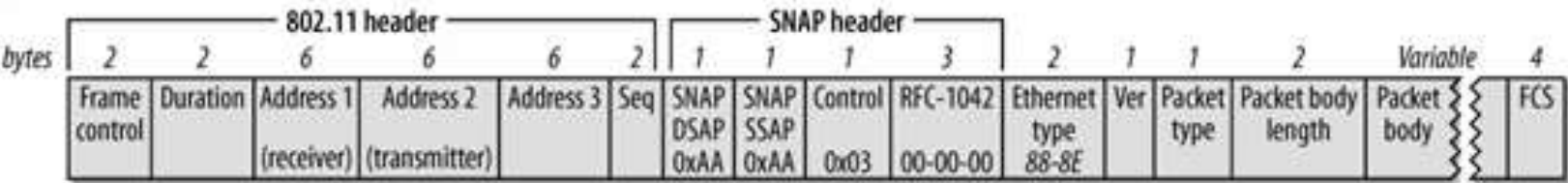
802.1X: Network Port Authentication

EAPOL Encapsulation

a) EAPOL on Ethernet



b) EAPOL on 802.11



802.1X: Network Port Authentication

EAPOL Encapsulation

Packet Type

Packet type	Name	Description
0000 0000	EAP-Packet	Contains an encapsulated EAP frame. Most frames are EAP-Packet frames.
0000 0001	EAPOL-Start	Instead of waiting for a challenge from the authenticator, the supplicant can issue an EAPOL-Start frame. In response, the authenticator sends an EAP-Request/Identity frame.
0000 0010	EAPOL-Logoff	When a system is done using the network, it can issue an EAPOL-Logoff frame to return the port to an unauthorized state.
0000 0011	EAPOL-Key	EAPOL can be used to exchange cryptographic keying information.
0000 0100	EAPOL-Encapsulated-ASF-Alert	The Alerting Standards Forum (ASF) has defined a way of allowing alerts, such as SNMP traps, to be sent to an unauthorized port using this frame type.

802.1X: Network Port Authentication

EAPOL Encapsulation

Packet Body Length

1. This two-byte field is the length of the Packet Body field in bytes.
2. It is set to 0 when no packet body is present.

Packet Body

- This variable-length field
- EAPOL-Start - 0
- EAPOL-Logoff -0
- EAP-Packet- one EAP frame
- EAPOL-Key – one key descriptor
- EAPOL-Encapsulated-ASF-Alert – one Alert message

802.1X on Wireless LANs

Sample 802.1X exchange on 802.11

